

Propuesta de arquitectura de banca digital para BP

Diseño C4, seguridad, operaciones financieras y resiliencia sobre Azure

Una arquitectura para web y móvil que integra el Core y los sistemas de cliente, protege las operaciones y desacopla auditoría y notificaciones sin duplicar el ledger.

Ejercicio de Arquitecto de Soluciones | Devsu

Documento de diseño · 25 de septiembre de 2026

1. Resumen ejecutivo

Se propone un canal digital resiliente en Azure, con SPA y app móvil detrás de una capa perimetral protegida, servicios de dominio cohesivos e integración anticorrupción con el Core bancario y el sistema de detalle del cliente. El Core conserva la autoridad sobre cuentas, saldos y asientos; BP no replica el ledger para servir lecturas ni ejecuta débitos en una base nueva. Las operaciones se aceptan con una referencia idempotente y un estado explícito, y se concilian con el Core y las redes interbancarias.

La arquitectura usa comunicación síncrona para lecturas y validaciones que determinan la respuesta inmediata, y mensajería para efectos secundarios durables (auditoría, notificaciones y procesos con estado). Una operación financiera nunca depende de que un email o push haya sido enviado. Cada transición crítica se registra con correlación, y el patrón Transactional Outbox evita perder eventos entre la base de dominio y el broker.

1.1 Revisión de la solución de referencia y cambios

La solución pública de referencia tiene una buena cobertura funcional y visual: README, Draw.io, C1/C2, varios C3 por dominio, infraestructura, cinco secuencias, documento editable/PDF y presentación. La propuesta presente conserva ese alcance, pero concreta o corrige los puntos que podrían cuestionarse en la defensa.

Hallazgo en la referencia	Optimización aplicada
El inventario de tecnologías presenta alternativas como SQL Server/PostgreSQL y MongoDB/Cosmos DB sin una elección ni criterio de selección.	Se fija PostgreSQL para estado por dominio y Azure Service Bus para colas/eventos. AKS queda condicionado a capacidades del equipo y necesidad real; Container Apps es el punto de partida de menor operación.
El README declara 16 millones de mensajes diarios, cifra que no aparece en el enunciado.	Se retira como requisito. Capacidad y costos se modelan con pico, mensajes, retención y SLA medidos.
Patrones como Saga, CQRS, Kafka y Cache-Aside aparecen en un catálogo, pero no se precisa bien dónde se aplican ni sus límites.	Se muestran en secuencias/componentes con responsabilidad concreta, condiciones de uso y fallos. No se agrega CQRS/Event Sourcing de extremo a extremo si no lo demanda la carga.
El nombre del producto de identidad puede interpretarse como CIAM listo para clientes sin validar la edición/capacidades configuradas.	Se especifica proveedor CIAM configurable, OIDC, Authorization Code + PKCE, MFA, passkeys, refresh-token rotation y requisitos de validación de contrato. En Azure se evalúa Entra External ID según soporte y ciclo de vida vigente.
Onboarding facial y biometría de acceso cotidiano se acercan conceptualmente.	Se separa prueba de identidad/liveness del proveedor durante el alta, y biometría local para desbloquear una clave/passkey. El rostro/huella no se transmite en cada inicio de sesión.
La transferencia puede parecer una transacción distribuida entre Core, rail, base y notificación.	Core sigue siendo ledger de autoridad; idempotencia, estado pendiente, consulta de resultado y conciliación cubren timeouts. Saga no promete atomicidad global ni reintenta débitos a ciegas.
Auditoría y persistencia frecuente se mencionan sin definir modelo de seguridad, retención o qué se cachea.	Se describen Outbox, proyección append-only, archivo inmutable segregado, acceso/retención y cache allowlist; se excluyen saldo autorizante, secretos y datos biométricos.
HA/DR/auto-healing no se demuestra con objetivos, mecanismo de failover y responsabilidad del Core.	Se agregan arquitectura multi-zona/región, RTO/RPO iniciales sujetos a BIA, runbooks y límites de auto-healing. El Core conserva su SLA y el canal concilia antes de reabrir operaciones.
C1 usa columnas de canales/procesos/dominio/Core/partners e incluye varios servicios internos dentro del contexto; C2 es un lienzo de 10,016 × 8,602 px con muchos detalles internos y límites apilados.	Se restablecen niveles C4: C1 muestra personas/sistema/relaciones externas; C2 muestra canales, BFF, servicios, almacenes y broker; C3 detalla un bounded context. Menos líneas cruzadas y etiquetas breves mejoran lectura.

Los cambios se basan en el inventario del README y la inspección visual directa de los diagramas C1/C2 públicos, junto con el enunciado recibido. Los documentos PDF/DOCX y el PPTX se enumeran en el inventario, pero no forman parte de la revisión visual completa de esta entrega. Antes de reutilizar su contenido, confirmar su origen y vigencia con el autor. Los archivos Mermaid son la versión editable propuesta y reemplazan los diagramas de referencia cuando sus niveles C4, conexiones o decisiones difieren.

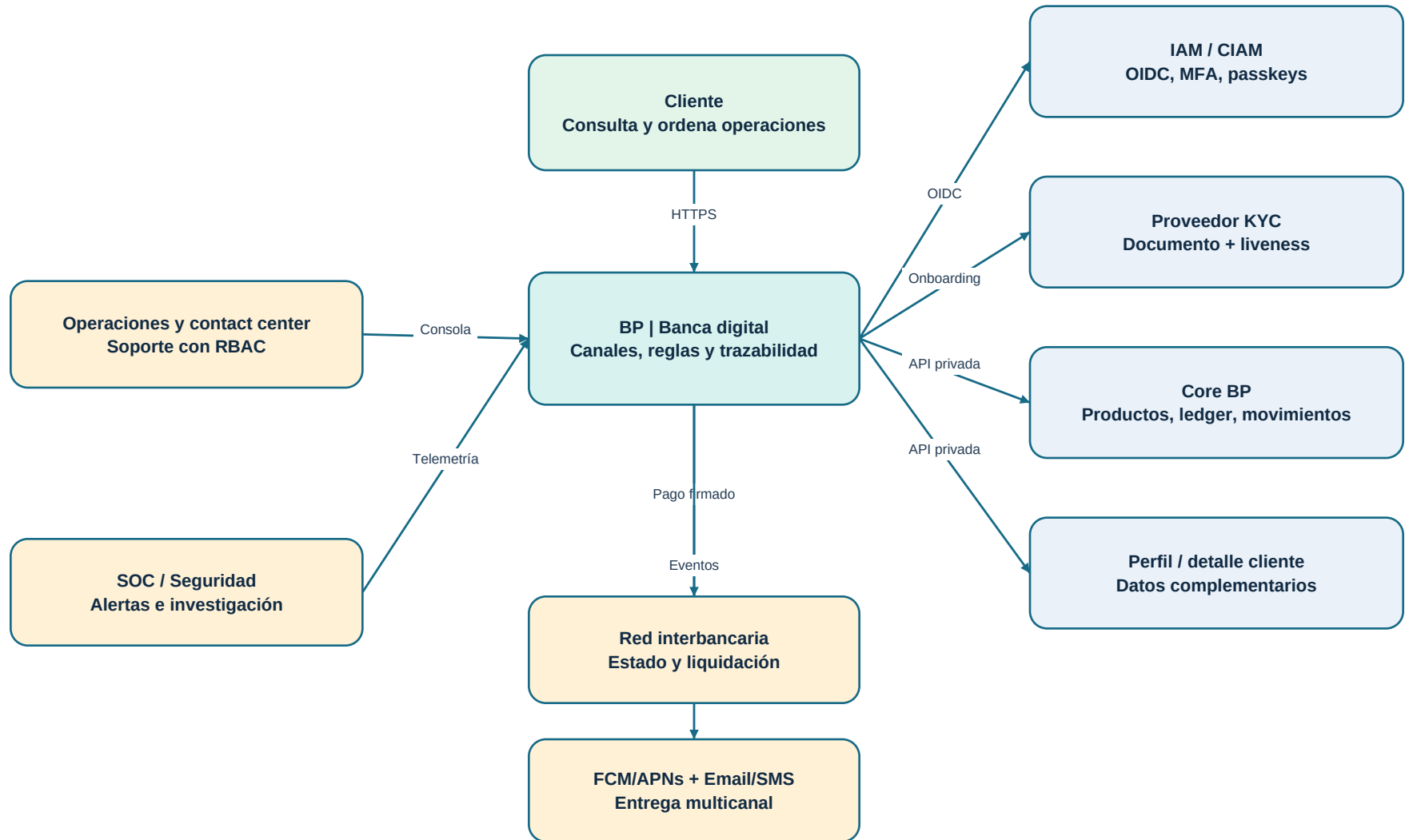
2. Alcance, actores y supuestos

Incluye onboarding digital con validación documental y prueba de vida, autenticación/autorización, consulta de productos y movimientos, pagos/transferencias propias e interbancarias, auditoría, notificación multicanal, operación y recuperación. El Core existente posee cliente básico, productos, movimientos y contabilización; un sistema de perfil complementa atributos detallados. No se asume API/contrato, SLA, capacidad de idempotencia ni protocolo de esos legados: el adaptador debe validar esas capacidades y acordar contratos con sus propietarios.

Actores: cliente, operaciones/contact center, seguridad/SOC, Cumplimiento y sistemas BP. Externos: Core, servicio de perfil/KYC, red de pagos interbancaria, proveedor de identidad configurable, proveedor de biometría/liveness, FCM/APNs y proveedores de correo/SMS. La información biométrica se trata como dato de categoría especial: minimizar captura/retención y no guardar imágenes o plantillas biométricas en la app ni en logs. Contratos de tratamiento, residencia y transferencia internacional requieren revisión legal.

C1 - Contexto

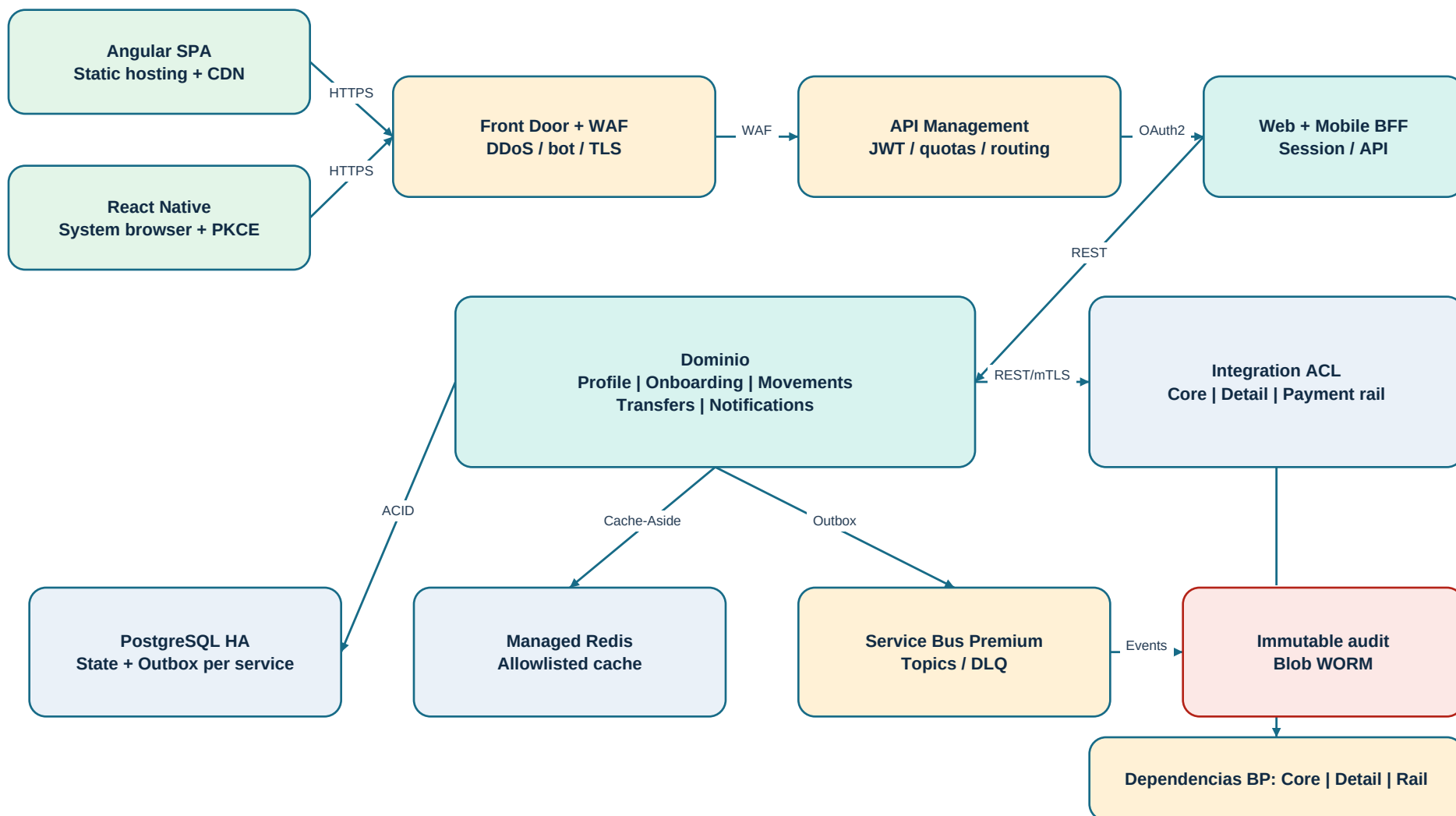
C1 | Contexto del sistema



El cliente usa los canales web o móvil para operar. El SBI coordina APIs y reglas de negocio; se integra con sistemas BP y proveedores bajo contratos autenticados. Operaciones y SOC consultan trazabilidad mediante roles separados. Véase [../diagrams/c1-contexto.mmd](#).

C2 - Contenedores

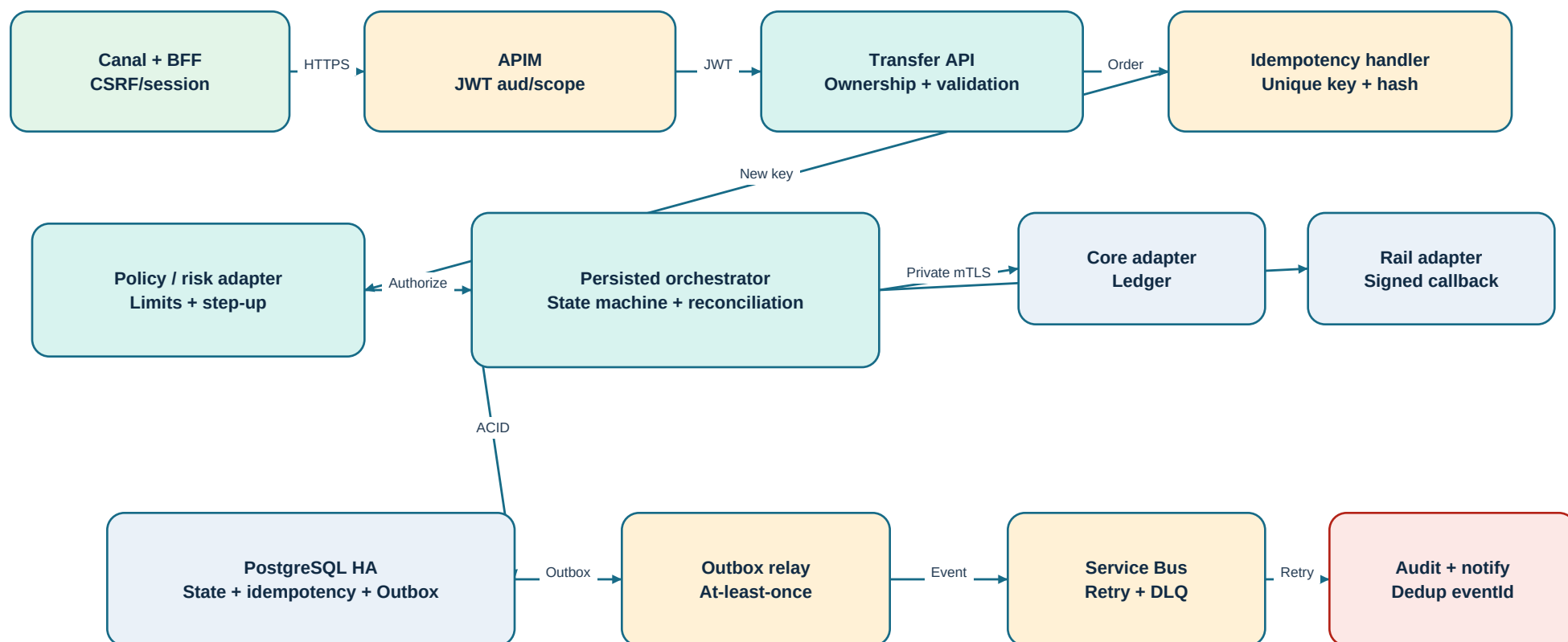
C2 | Contenedores y límites de confianza



El perímetro incluye Front Door/WAF, API Management y dos BFF (web/móvil). Los dominios de perfil, onboarding, movimientos, transferencias y notificaciones se despliegan en contenedores. PostgreSQL almacena estado operativo y outbox de los dominios; Redis guarda lecturas aptas para caché; Service Bus separa comandos/eventos; Blob Storage con inmutabilidad conserva evidencia de auditoría; Key Vault administra secretos y llaves. Véase `../diagrams/c2-contenedores.mmd`.

C3 - Componentes de transferencias

C3 | Componentes del servicio de transferencias



El C3 muestra el camino de una orden con API segura, verificación de límites/beneficiario, idempotencia, orquestación con estado, adaptadores Core/red, persistencia transaccional + Outbox y consumidores de auditoría/notificaciones. Véase [../diagrams/c3-transferencias.mmd](#). Las llamadas usan TLS 1.2+; mTLS/OAuth client credentials para servicio a servicio donde las contrapartes lo soporten; identidad de workload administrada dentro de Azure. El gateway valida JWT, audiencia, issuer, scopes y límites, pero el servicio vuelve a autorizar por recurso y titularidad.

4. Flujos esenciales

Inicio de sesión

La SPA inicia Authorization Code + PKCE contra el proveedor OIDC y termina en un BFF que guarda tokens del lado servidor; cookie de sesión opaca Secure, HttpOnly, SameSite, protección CSRF y rotación. Alternativamente puede ser cliente público con PKCE y tokens solo en memoria, nunca en localStorage; BFF reduce exposición XSS, a cambio de mantener sesión servidor. En móvil el SDK oficial usa navegador del sistema, deep link verificado y PKCE S256. Se deshabilitan Implicit y Resource Owner Password Credentials. Access tokens breves y de audiencia mínima; refresh token rotation con detección de replay; step-up MFA para beneficiarios nuevos, dispositivo nuevo, cambio de credenciales y montos/riesgos altos.

La huella/Face ID local desbloquea una clave privada del dispositivo o un passkey (FIDO2/WebAuthn); la biometría nunca se envía al banco ni sustituye la autenticación del servidor. El dispositivo demuestra posesión criptográfica. Se ofrece fallback con contraseña + MFA y recuperación con verificación reforzada. Onboarding prueba identidad mediante documento + selfie con liveness y revisión de fraude; el proveedor entrega resultado/score y referencia, no una plantilla reutilizable. La decisión de alta requiere reglas de riesgo y revisión manual para casos ambiguos. Un enrolamiento aceptado vincula identidad bancaria y sujeto OIDC de forma atómica desde el punto de vista de negocio, con estados pendientes/reintento/rechazo auditables.

Consulta de movimientos

El BFF valida sesión y el servicio consulta proyección de movimientos o Core mediante adapter. Datos detallados se enriquecen desde Perfil solo si el caso los requiere. Paginación por cursor, ventana temporal y límites; caché opcional de catálogo/perfil no sensible. Una caída del Core produce degradación explícita (último dato con marca temporal si política lo permite, o error), nunca se presenta caché como saldo autoritativo.

Transferencias

1. Canal envía orden, Idempotency-Key única, importe decimal con moneda, cuenta origen/destino y desafío step-up si aplica.
2. API valida JWT/scope, CSRF en BFF, esquema, límites de petición y cuota; servicio valida titularidad, estado, límites, beneficiario y riesgo con dato fresco.
3. Orquestador persiste RECEIVED y pasos con clave idempotente; aplica reserva/débito según contrato Core y procesa respuesta síncrona o callback. Estado final POSTED, REJECTED o PENDING_RECONCILIATION no se infiere por timeout.
4. La transacción de estado + Outbox es atómica en la base del orquestador. Relay publica evento versionado a Service Bus; el consumidor escribe auditoría y genera aviso.
5. En timeout se consulta estado por referencia antes de reintentar. No se reenvía un débito ciegamente. Compensación solo procede cuando el contrato del Core/rail la soporta; reverso financiero no equivale a rollback de base distribuida.

Sagas para transferencias interbancarias expresan pasos/compensaciones como máquina de estados persistida, con timeout, callback firmado, reconciliación de pendientes y proceso operativo. Si Core ofrece operación atómica/idempotente, delegar el movimiento contable allí es preferible a simular atomicidad con microservicios.

Notificación

Evento TransactionPosted en Outbox -> broker -> servicio de notificaciones -> plantilla con datos mínimos y preferencias -> adaptadores Push (FCM/APNs) y Email/SMS (proveedores independientes). La bandeja interna se persiste antes de llamar al proveedor externo. Estado de entrega es eventual; DLQ, deduplicación por eventId, reintentos con backoff/jitter y fallback solo cuando política/consentimiento/costo lo permite. No colocar saldo completo, OTP ni datos sensibles en push/SMS/email.

5. Persistencia y consistencia

- **Core:** única fuente contable para saldo/asiento; contrato de consulta y comando detrás de adaptadores separados.
- **PostgreSQL por servicio:** estado de onboarding, transferencias/orquestación, notificaciones y outbox, con esquema/credenciales aislados y transacciones ACID locales. No hay consultas cross-schema ni base compartida entre microservicios.
- **Proyecciones:** opcionales para historial/consulta, actualizadas por eventos y marcadas con fecha/versión de sincronización; no deciden si hay fondos disponibles.
- **Redis Cache-Aside:** catálogos y perfil de baja volatilidad con TTL/invalidación y cifrado/red privada. Excluir credenciales, secretos, OTP, PAN (si aplica), biometría, saldo autorizante e información que la política no permita.
- **Auditoría:** separar auditoría de negocio, logs de seguridad/IAM y telemetría operacional. Persistir actor pseudónimo, acción, recurso, resultado, timestamp UTC, correlation/trace ID, versión y motivo; filtrar tokens y PII. Evento append-only + exportación a almacenamiento con policy WORM, RBAC segregado, retención/borrado legal aprobados, hash chain/firma y evidencias de acceso. Kafka/broker no es el archivo legal de auditoría.
- **Patrones de acceso:** Repository para encapsular almacenamiento y Cache-Aside Decorator alrededor de lecturas idempotentes, con métricas de hit/miss y invalidación. Transaccional Outbox para publicar sin dual-write. Evitar Event Sourcing total: el ledger queda en Core; conservar eventos de negocio necesarios para trazabilidad y replays acotados.

6. Seguridad y normativa

Controles: TLS externo e interno, cifrado at-rest con llaves administradas/rotadas, managed identities, Key Vault, segmentación privada, egress allowlist, WAF/bot/rate limit, DDoS, validación de entrada, CSP, protección CSRF, SAST/DAST/dependency scan, SBOM y firma de artefactos, hardening de imágenes, RBAC least privilege, PAM/JIT para operación, separación de funciones y alertas SOC. Token no es autorización completa: validar titularidad/ownership en cada recurso. Confirmación transaccional muestra importe/beneficiario y enlaza el desafío con los datos de la orden.

Marco Ecuador a evaluar con asesoría legal y Cumplimiento:

1. **LOPD y RGLOPD:** base de legitimación, transparencia, finalidad/minimización, derechos, seguridad, evaluación de impacto cuando corresponda, gestión de encargado, incidentes, retención/eliminación y transferencia internacional. La imagen facial/dato biométrico exige evaluación reforzada de necesidad, proporcionalidad, controles y contrato del proveedor. Aplicar normativa SPDP vigente de transferencias (incluida resolución 2026-0004-R) según rol y destino.
2. **Código Orgánico Monetario y Financiero y normativa de Junta/Superintendencia de Bancos:** sigilo/reserva financiera, seguridad de canales, gestión integral de riesgo operativo y tecnológico, continuidad/contingencia, incidentes, auditoría y proveedores críticos. Verificar versión/capítulo aplicable al tipo de entidad y fechas de vigencia.
3. **Normas de riesgo operativo y seguridad/ciberseguridad de SB:** matriz de riesgos, controles, continuidad, pruebas, proveedores y evidencia auditable. Diseñar mapeo de control y responsable, no afirmar certificación automática.
4. **Prevención de lavado/financiamiento ilícito y KYC:** controles de identidad y listas/monitoreo los determina Cumplimiento; onboarding integra interfaces aprobadas sin persistir copias innecesarias.
5. **PCI DSS** solo si el alcance procesa, almacena o transmite datos de tarjeta; no asumir que aplica a transferencias de cuenta. ISO 27001/27017/27018, NIST CSF y OWASP ASVS/MASVS son marcos de referencia, no leyes ecuatorianas.

7. Disponibilidad, DR y objetivos

Diseño inicial sujeto al BIA/SLAs del Core: disponibilidad objetivo 99.95% mensual para APIs de lectura, $RTO \leq 60$ min y $RPO \leq 5$ min para estados del canal (el ledger es Core y se gobierna por su SLA); revisar si el negocio requiere objetivos más estrictos. Zonal redundancy para APIM, cómputo, base y broker; balanceo multi-zona, réplicas síncronas cuando el servicio lo permita, health/readiness probes, autoscaling, despliegue rolling/canary y auto-healing. Región secundaria emparejada con backup cifrado/geo-redundante y restauración probada; failover DNS/Front Door y runbooks. No declarar activo-activo hasta resolver consistencia, escritor único, idempotencia y conflicto entre regiones.

Resiliencia por dependencia: timeouts por presupuesto, circuit breaker, retry solo idempotente con backoff exponencial + jitter, bulkhead/concurrency limits, límites de cola, DLQ con redrive controlado, graceful degradation y reconciliation queue. Core/rail con cuota/capacidad pactada; semáforo y circuit breaker sin fallback a saldo cacheado. Pruebas de restauración/failover y ejercicios de caos acotados.

8. Observabilidad y excelencia operativa

OpenTelemetry para trazas, métricas y logs correlacionados; Azure Monitor/Application Insights, Log Analytics, Managed Prometheus/Grafana y alertas al SOC/operación. Métricas de negocio: transferencia por estado, latencia Core/rail, idempotency hit, importe en conciliación, edad de DLQ, retraso Outbox, latencia/pérdida de notificación. SLO/SLI y error budgets; alertar sobre síntomas e impacto cliente. Logs estructurados sin bearer token, OTP, biometría ni datos bancarios innecesarios. Auditoría y telemetría tienen almacenes, acceso y retención distintos.

CI/CD con IaC (Bicep/Terraform), entornos segregados, aprobación y segregación de funciones, secrets fuera del pipeline, escaneo de supply chain, despliegue progresivo y rollback. Runbooks para Core down, rail timeout, cola bloqueada, región degradada, fuga de credenciales y failover. Auto-healing repara instancias y workers; no vuelve a ejecutar comandos financieros sin comprobar su resultado.

9. Costos y escalado

El volumen de 16 millones/día que aparece en la solución de referencia no procede del enunciado; excluirlo como dato garantizado. Dimensionar con tráfico pico, tamaño de mensaje, concurrencia, retención, latencia del Core, envíos por canal y SLA reales. Empezar con PaaS administrado, escala automática, budgets y alertas, reservas para cargas base, retención de logs por clase, muestreo de trazas de éxito y muestreo 100% de errores/operaciones financieras según política. Evitar Kafka + AKS + múltiples bases documentales si Service Bus y PostgreSQL cubren necesidades. Usar AKS cuando haya equipo plataforma y requisitos de control/portabilidad; para equipo pequeño o primera versión, Container Apps reduce carga de clúster. Revisar costo de IP fija/NAT, APIM tiers, WAF, geo-replicación, retención WORM y SMS internacional.

10. ADR resumidos (decisión y razones)

ADR	Decisión	Razón 1	Razón 2	Alternativas consideradas
01 Nube	Azure administrado, componentes por necesidad	APIM, Entra, Key Vault y Monitor integran identidad/operación	Zonas, regiones y servicios administrados reducen tareas manuales	AWS equivalente; híbrido si Core/red lo exige
02 Web	Angular + BFF	BFF evita exponer refresh/access tokens al JS persistente	Angular favorece módulos, DI y gobierno de equipos enterprise	React/Next.js; SPA pública con tokens solo memoria
03 Móvil	React Native; Flutter como opción válida	Ecosistema TS y reutilización de conocimiento UI/API web	SDK nativo y biometría/passkeys mediante módulos con mantenimiento	Flutter ofrece UI consistente/rendimiento; Kotlin/Swift elevan costo doble
04 Identidad	OIDC Authorization Code + PKCE S256	Flujo actual para clientes públicos y redirecciones	PKCE protege código; navegador externo aísla credenciales en móvil	Implicit/RoPC descartados; BFF como cliente confidencial web
05 Integración	API Gateway + BFF + adapters/ACL	Gateway centraliza políticas perimetrales	BFF adapta contratos por canal; ACL desacopla formatos legados	Gateway directo a microservicios aumenta acoplamiento/exposición
06 Mensajería	Azure Service Bus, Outbox e idempotencia	Entrega durable, DLQ y colas para comandos/eventos de negocio	Menor carga operativa y buena afinidad con Azure	Kafka solo si orden/retención/replay/caudal medido lo justifican
07 Datos	Core autoritativo; Postgres por dominio	Preserva fuente contable y transacciones locales ACID	Evita base compartida y costos/consistencia de polyglot sin necesidad	Cosmos para acceso global/escala probada; no para reemplazar ledger
08 Cache	Cache-Aside con allowlist	Reduce latencia/carga en catálogo y perfil	Invalidación/TTL explícitos limitan obsolescencia	No cachear información; nunca cache de saldo para autorizar
09 Auditoría	Eventos append-only + WORM	Resistencia a alteración y separación de permisos	Correlación reconstruye actor, acción y resultado sin guardar secretos	Solo logs técnicos es insuficiente; Event Sourcing completo excesivo
10 HA/DR	Multi-zona + región secundaria activa-pasiva	Zona cubre fallos locales con baja latencia	Activo-pasivo evita conflictos contables multi-región	Activo-activo solo con requisitos/consistencia y Core aptos
11 Biometría	Liveness/KYC proveedor + biometría local para passkey	Liveness ayuda contra suplantación en alta	Autenticación local evita transmitir biometría al backend	Face unlock del SO es UX, no factor remoto por sí mismo

11. Riesgos abiertos y decisiones que requieren BP

Confirmar: SLA/contratos del Core y red; soporte de idempotencia, consulta por referencia y reverso; autoridad de saldos; APIs privadas y latencia; objetivos de tráfico/pico; requisitos de residencia; retención de auditoría/KYC; instrumento legal y base de datos biométricos; proveedor de CIAM y capacidades PKCE/step-up/passkeys; canales y disponibilidad de proveedores; población objetivo de RTO/RPO; costos y operación 24x7. Estas dependencias determinan diseño detallado y no deben darse por resueltas por el diagrama.

Fuentes oficiales y estándares

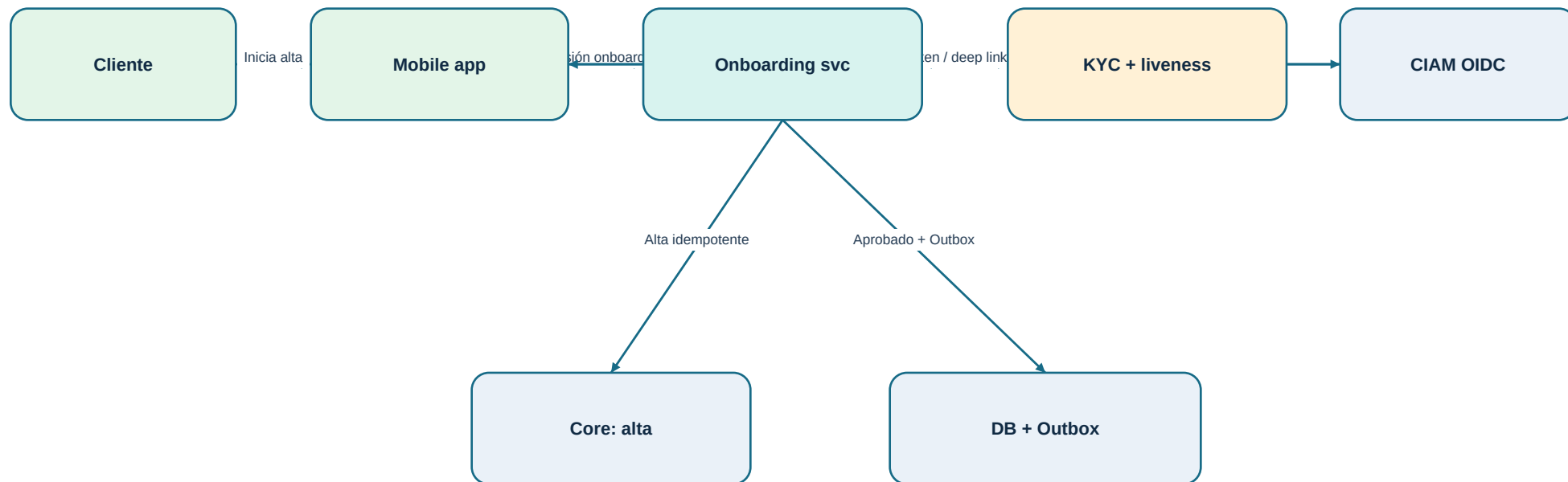
- IETF, RFC 9700 - OAuth 2.0 Security Best Current Practice.
- IETF, RFC 8252 - OAuth 2.0 para aplicaciones nativas.
- SPDP Ecuador, [resoluciones y normativa](#), incluida normativa de transferencias/comunicaciones internacionales vigente.
- Superintendencia de Bancos, [Codificación de las Normas - Libro Uno](#), riesgo operativo y capítulos aplicables.
- Superintendencia de Bancos, [Normativa del sistema controlado](#).
- OWASP, [Application Security Verification Standard](#) y [Mobile Application Security](#).

Fecha de consulta normativa: 25 de septiembre de 2026. La lista es un mapa de análisis, no opinión legal ni declaración de conformidad.

Diagramas de apoyo

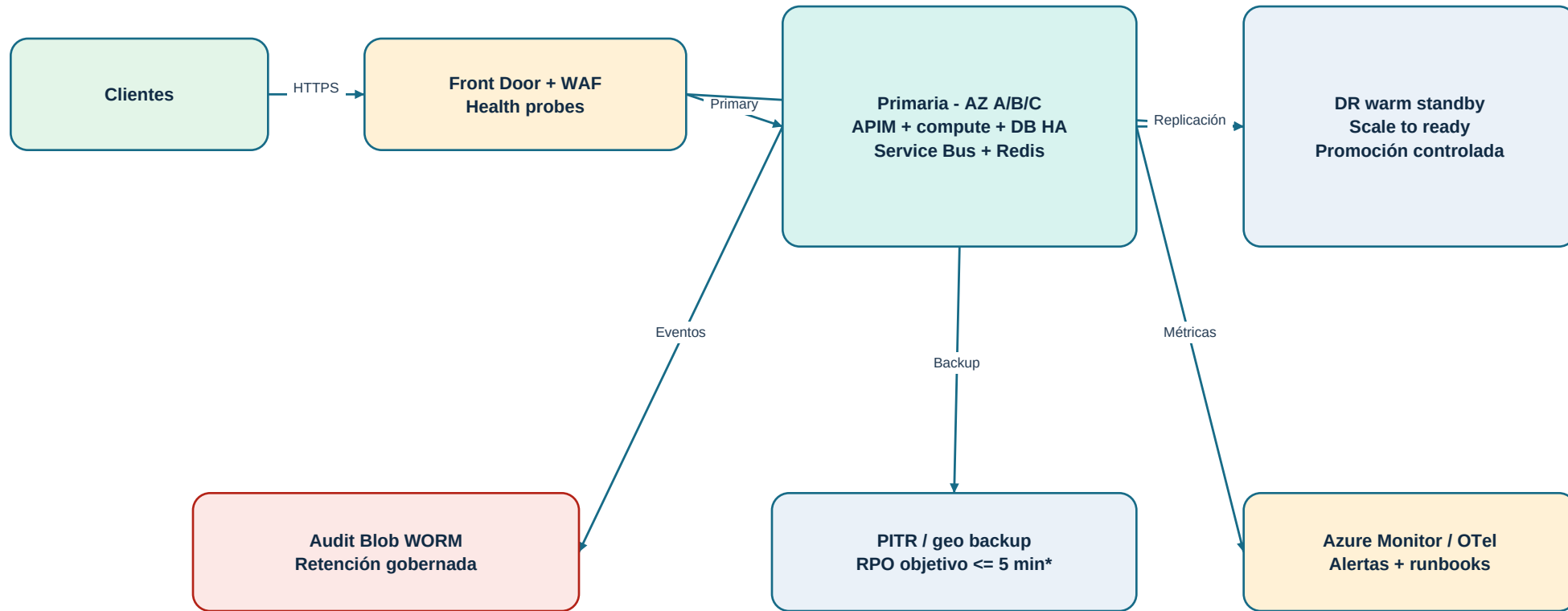
Estos diagramas resumen los flujos y despliegue. Los archivos Mermaid fuente se entregan en la carpeta diagrams.

Secuencia | Onboarding y autenticación



El proveedor biométrico valida identidad durante el alta. En autenticación habitual, la biometría permanece en el dispositivo y desbloquea una credencial criptográfica.

Infraestructura | Alta disponibilidad y recuperación



* Objetivos de ejemplo para discusión. Deben validarse en el análisis de impacto y con los SLA del Core; el Core mantiene autoridad contable.